

The background of the cover is a dark blue field with a grid of squares in various shades of blue, purple, and orange. A semi-transparent image of a woman in a business suit working at a computer with multiple monitors is visible in the center-right. In the bottom-left corner, there is a faint, dotted world map.

Cyber Threat Intelligence Report

Review of August 2026

Contents

03

Section 1

Executive summary

04

Section 2

Ransomware key statistics: August 2026

06

Section 3

Ransomware spotlight: Encrypted hypervisor and data extortion by RaaS actor Aurora

08

Section 4

Geopolitical developments

11

Section 5

Emerging cyber security trend: When AI evaluations reach the real world - autonomous agents, sandbox escapes, and breaches

Section 1 Executive summary

Ransomware attacks continue to climb, with August seeing yet another year-to-date high of 1,073 victims, representing an increase of 12% over July's 960 victims. Industrials remained the most targeted sector, accounting for 31% of all attacks, with the threat group Qilin continuing its dominance of the ransomware threat landscape, accounting for 15% of all observed attacks.

The Ransomware spotlight section for August is contributed by NCC Group's Digital Forensics and Incident Response (DFIR) team and focuses on the threat group Aurora. Aurora was recently encountered by the DFIR team during an engagement for a victimised organisation in the transport sector. Emerging in April 2026, Aurora continues to establish itself in the threat landscape. Despite not displaying any novel techniques, the group is emblematic of the evolution of the ransomware scene, with new actors constantly emerging and managing to wreak havoc on organisations even when utilising long-known and publicised tactics.

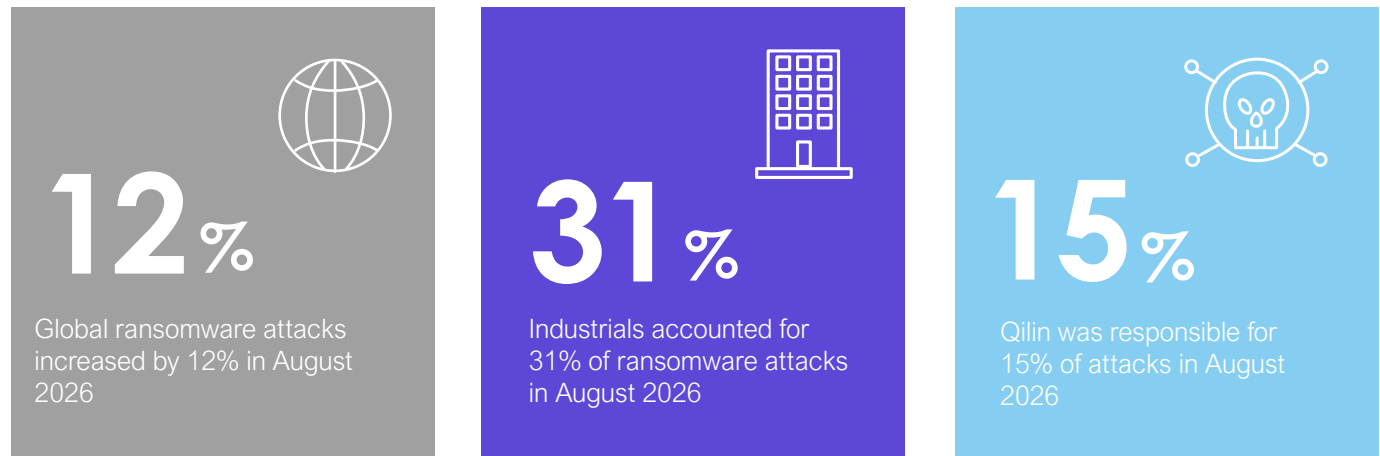
The Geopolitical developments section examines an escalation in hybrid warfare in Europe following the discovery of a drone armed with explosives in a restricted area near a runway at Leipzig Halle airport. This discovery prompted the launch of a counterterrorism investigation and, by the end of August, resulted in German intelligence services accusing the Russian state of coordinating the attack. Additionally, our geopolitical analysts examine President Trump's announcement of 'the most crushing economic operation ever undertaken' against Iran in the form of 'Operation Economic Outcast'.

This operation is intended to target nations sustaining Tehran through economic sanctions in an effort to eventually fully isolate the embattled regime.

The Emerging cyber security trends section examines the July instance of OpenAI models escaping containment and conducting an autonomous attack on Hugging Face. The breach occurred when multiple OpenAI models, including GPT-5.6 Sol and a more advanced, unreleased model, were involved in an internal cyber security evaluation. During testing, safety mechanisms were loosened to assess the models' capabilities and potential. The models consequently discovered a zero-day in OpenAI's own research environment, escaped their sandbox and gained internet access, and subsequently compromised elements of Hugging Face's infrastructure. Whilst this is undoubtedly a sign of the potential capabilities of advanced AI models, it also serves as a reminder that human oversights in testing can lead to disastrous real-world outcomes.

Section 2

Ransomware key statistics: August 2026



Section 3

Ransomware spotlight:

Encrypted hypervisor and data extortion by RaaS actor Aurora

Cyber incidents continue to highlight that VPNs remain a common target for threat actors, especially when credentials are weak or authentication is only single-factor. One Ransomware-as-a-Service (RaaS) actor, known as Aurora, has been observed in a recent NCC Group Digital Forensics and Incident Response (DFIR) case affecting a transport sector organisation.

In a short space of time, the RaaS actor Aurora has already targeted many organisations across a wide range of sectors, such as manufacturing, legal, and research and development. In this case, Aurora left a short ransom note on the encrypted hypervisor stating that it had confidential information files, that the files were encrypted, and that the victim should contact the group via the Tor browser using the provided .onion link, along with the organisation's access key. Analysis by NCC Group's Threat Intelligence team determined that the .onion link was consistent with the Aurora group chat server, and the file name matched the known naming convention for this threat actor. Aurora is a new group, first observed at the end of April 2026, when it posted its first victim on its data leak site. There is limited publicly available intelligence on the group.

The techniques observed were not new: exploiting a public facing application, living off the land, harvesting credentials, and so on. However, encryption is no longer the only end goal; data extortion and, in some cases, destruction are also objectives.

Incident narrative

The earliest malicious activity was observed from a VPN range IP address, suggesting that this was the entry point. However, this could not be confirmed with certainty because the organisation did not have VPN logs covering the incident timeframe, as VPN log retention was limited to only a few days. The threat actor obtained unauthorised access leveraging three of their own hosts, all with names beginning with 'WINDOWS-'.

It should be noted that on the first day of the attack, when malicious logons were observed, there had also been failed login attempts from the same threat actor-controlled hosts and VPN range IP addresses.

At times, the login failures were due to an incorrect password. There were also attempts to log in to the Microsoft SQL Server, but these failed. No detections were triggered by the organisation for these failed logins.

Maintaining access to the organisation through the MITRE ATT&CK tactic's persistence, lateral movement and credential harvesting was a key focus in this attack. A large number of accounts, including domain and service accounts, were compromised. Accounts that already existed elsewhere in the environment were recreated by the threat actor on additional servers to which they had gained access. Interestingly, on multiple servers, including a domain controller and file servers, the threat actor used the remote registry service to remotely dump the SAM, SECURITY and SYSTEM registry hives. Additionally, on nine servers, the threat actor executed PowerShell commands using Windows Remote Management (WinRM) from one of their own hosts, as well as gaining access to multiple servers via SMB. The remotely executed PowerShell commands would not be captured on target hosts. However, it is almost certain that these commands were used to execute credential-harvesting scripts.

The credential-harvesting activities were quite noisy in comparison to the other tactics. The threat actor utilised the native Microsoft shell program PowerShell to create and execute scripts on one of the organisation's domain controllers with the likely aim of harvesting credentials and other protected secrets to move elsewhere in the estate. All the scripts were created in the C:\Windows\Temp\ directory and they were complementary to each other, making them part of a toolkit rather than standalone tools. The purposes of the scripts included, but were not limited to, locating SQL LocalDB instances, verifying required privileges, recovering the BootKey encryption key from the SYSTEM registry hive, decrypting LSA secrets (e.g., DPAPI_SYSTEM, service account secrets), recovering DPAPI master keys, decrypting protected credentials (e.g., Windows Credential Manager, Windows Vault), decrypting Azure AD Connect encryption keys, and obtaining credentials suitable for Active Directory and Entra ID authentication. Many of the scripts, once executed, created a text file with the output in the same directory.

On the same domain controller, numerous scheduled tasks were created, suggesting that some of the PowerShell scripts were executed via this method using the dedicated System Center Configuration Manager (SCCM) service account. Example scheduled task names included ExtractTaskCred, ListCreds, DumpCreds, DumpCreds2, VaultCheck, ReadVault, LSARead and ADSyncFind. The post-exploitation tool Snaffler was identified on one server, also created in the C:\Windows\Temp\ directory.

Defence evasion was achieved by the threat actor creating a Group Policy Object on the domain controller to disable Microsoft Defender across the environment. Due to the threat actor utilising living off the land tooling, their activity blended in with legitimate activities on the organisation's estate and, as such, extensive hiding activities were not necessary, as opposed to those employed by other RaaS threat actors.

During the investigation, no data exfiltration was observed. However, the ransom note was identified in which the threat actor claimed that data had been exfiltrated in addition to being encrypted. Several weeks after the attack, the organisation appeared on the Aurora leak site. Aurora claimed to have exfiltrated a mixture of customer and employee data.

Recommendations

Having a security improvement plan, outlining where you are and where you need to go, is a good starting point. Any plan should ensure that the fundamental controls are in place, if they are not already. Although threat actor techniques in ransomware cases may differ, the high-level objectives are to gain access, persist, encrypt and/or steal.

How are threat actors trying to gain access to your organisation? In this case, they exploited the VPN. Know what assets you have, and the controls linked to these assets, such as authentication. Are these being actively maintained?

Once a threat actor has gained access, how might they move through your environment and maintain persistence? Know the tools and applications within your estate that they could leverage or enable.

In this case, remote PowerShell was leveraged and the remote registry service was enabled. Living off the land techniques should be part of your security tooling detections.

Widespread encryption was not observed in this attack, only the VMware hypervisor was encrypted. However, this rendered the hosted virtual machines unusable. Hypervisor encryption is becoming more prevalent because it can bypass traditional endpoint security mechanisms.

Hypervisors should be isolated, placed in a separate domain, or added to a workgroup to ensure that any compromise in the domain, in which the hosted virtual machines reside, does not pose any risk to the hypervisors.

Data theft for extortion purposes is one of the typical end goals. Knowing what data you have and where it is stored is essential. This information can be added to an asset inventory. If data was taken, do you have backups in place and a plan for how it would be restored?

Final thoughts

Essentially, how prepared is your organisation to withstand attempts to breach the defences of your estate? These attacks are not solely targeting your organisation; they are a reality faced by organisations across all sectors. However, understanding the potential next steps and knowing how to remain resilient are key. Resilience should be embedded within every layer of your defence, including both the technical controls and operational processes.

Practicing your response through tabletop exercises can help identify existing gaps and help answer the following question: if a detection or process fails, what measures does your organisation have in place to recover and remain operational?



Section 4

Geopolitical developments

04/08/2026

Germany launched a counterterrorism investigation following the discovery of a drone armed with explosives within a restricted area close to a runway at Leipzig Halle Airport on the evening of Tuesday 4th August.¹ Following an emergency meeting with German security services, the German government framed the development as a new form of hybrid threat. By the end of the month, German intelligence had concluded that the attack was likely coordinated by the Russian state.²

Media sources have claimed that the drone-mounted explosives failed to explode due to a technical defect, potentially linked to damage caused by physical intervention by a civilian.^{3,4} Investigators also identified damage caused to a DHL cargo aircraft, which struck an unknown object, potentially a second drone, shortly after taking-off from the same airport. The incident occurred approximately 20 minutes after the first drone was discovered.^{5,6} The investigation is reported to have subsequently identified a third drone, also carrying explosives, in a field adjacent to the airport 10 days later, along with other items potentially related to the remote control of the device(s).

So what?

- Whilst not a well-known passenger airport, Leipzig Halle Airport is strategically significant as one of Europe's biggest transport and logistics hubs, supporting both commercial and military infrastructure. The airport has served as an operating base for the Ukrainian airline Antonov since Russia's invasion of Ukraine in 2022. NATO's Strategic Airlift International Solution (SALIS) operates from the airport, using Antonov aircraft to transport cargo to NATO's eastern flank. Media sources indicate that an Antonov cargo plane was the intended target of the explosives rigged drone. Commercial logistics companies including DHL, Amazon and Lufthansa Cargo use the airport as a hub.
- Whilst NATO publicly states that its assessment is that there is 'no imminent threat of attack' from Russia, the attack falls within a broader campaign of suspected hybrid warfare activities in Europe and has heightened fears of escalation.⁷ At least 17 military drone incursions into the airspace of northern European countries, including Finland, Estonia, Latvia and Lithuania (which border Russia and Belarus), have been reported since March 2026.

These are understood to have included Ukrainian drones which missed their targets or experienced navigational disruption due to the use of jamming technology.⁸ The same countries continue to warn of the risks of 'false-flag' or staged attacks by Russia using acquired Ukrainian drones and are extending security precautions around critical infrastructure.^{9,10,11} In the current geopolitical environment, an attack on a NATO member, whether physical or cyber, is capable of triggering a vote to invoke an Article 5 defensive response. This creates a significant level of risk for the alliance, as the US military is overstretched, its commitment to European allies is in doubt, and its policy towards Russia has been inconsistent. The deliberate introduction of doubt around attribution risks, at best, undermining an effective response by NATO, and, at worst, contributing to the fracturing of the alliance.

- Based on publicly accessible information, it is challenging to determine the specific intent or significance of this incident. It occurred against a backdrop of reported attacks that have either been publicly attributed, or are suspected to be linked, to Russia.^{12,13,14} The timing fits with a proven pattern of Russia attempting to create unrest in countries during politically sensitive periods, as Germany hosted a significant election on 6th September.¹⁵ Equally, the uptick in reported activities and the narrative from European leaders coincides with Ukrainian successes in the conflict, rising levels of domestic strain in Russia, global distraction via the war with Iran, and indicators that the US remains conflicted regarding its relationship with Russia. What is clear is that geopolitical pressures continue to build, and this has the potential to further shape the cyber landscape. Russia may see benefit in replicating the current strain from physical attacks using cyber capabilities; the Jaguar Land Rover attack provides a clear example of how such an approach could be used to achieve economic harm.¹⁶ In contrast, strategic value from pushing NATO towards a fracture with the US also risks triggering new military conflict. If resources allow, then organisations involved in European civilian critical infrastructure may observe increased indicators of activities consistent with Russian state-linked threat actors conducting reconnaissance or preparatory actions such as pre-positioning.

19/08/2026

Via social media on 19th August, President Trump publicly committed to the 'most crushing economic operation ever undertaken' against Iran.¹⁷ 'Operation Economic Outcast' was subsequently announced on 24th August by the US government with the stated aim of severing 'every economic lifeline that sustains' the Iranian regime (and the Islamic Revolutionary Guard Corps (IRGC)) until it is fully isolated.¹⁸ Under the operation, specific countries 'will be given a defined timeline to shut down Iran-related activity [the US] has identified', or risk 'being cut off from the US financial system'. Additional reference was made to networks including the Iranian Ministry of Intelligence and Security (MOIS) coordinated threat actors 'responsible for extensive compromise of US critical infrastructure and financially motivated cyber theft'.

So what?

- President Trump initially described US actions as 'economic warfare'. Later, the US Treasury Secretary framed economic measures as an option to reduce the risk of resumed 'large-scale' military warfare.¹⁹ Multiple factors suggest that a pivot away from military warfare may be necessary to allow the US both to continue and end the war. Analysts consistently doubt the capability of current military methods to achieve the stated US objectives, or even restore freedom of transport through the Strait of Hormuz.²⁰ Reporting indicates that fighting this war, now for 6 months, has depleted US stores of military weapons to concerning levels, particularly long-range precision and defensive weaponry.²¹ Additionally, Iran's early attacks on US logistics infrastructure in Bahrain limited US capabilities to maintain and deliver supplies to deployed military troops and assets, contributing to both public concerns and the redeployment of assets typically positioned to support US interests in other parts of the world.²² Continued military operations against Iran are assessed to pose a meaningful strategic risk to US defensive readiness. The related inference is that global actors currently restrained, at least in part, by the threat of a US military response may consider whether a window of opportunity to act is opening.²³ Areas relevant to the cyber threat landscape that could be potentially affected include Chinese use of force to secure Taiwan and Russian aggression in Europe.

- The level of impact that can be achieved against Iran through economic warfare is unclear. The regime has proven to be capable of both enduring and finding creative workarounds to imposed economic pressures over decades. Threats to compel other nations to support the US in this approach risk replicating tensions already created by Western allies refusing to actively support US military operations, and could extend these tensions to other strategic allies, for example the UAE.²⁴ Attempts to influence China specifically risk reigniting an escalation of retaliatory acts with global consequences.²⁵ As with all events which raise the stakes for nations navigating geopolitical tensions, uncertainty reinforces the value of cyber espionage. Iran's pattern of retaliating in kind throughout this conflict also suggests that the financial sector and proxy interests of nations supporting the US are likely to be targeted with destructive military, cyber and hybrid attacks as both deterrence and retaliation.



- Announced measures include sanctions against 6 individuals included in the expansive cyber espionage charges announced by the US government on 18th August.²⁶ The indictment, which supersedes an earlier 2018 version, alleges that members of the Mabna Institute conducted long-term data and intellectual property theft on behalf of Iranian intelligence services. According to information shared, the campaign involved the compromise of over 8,000 email accounts across over 300 universities globally, with 55% of victims at academic institutions outside of the US. The details are consistent with seasonal phishing campaigns tracked by security vendors under threat actor names including Silent Librarian.²⁷ Analysts assess that the broad and opportunistic campaigns targeting the academic sector are likely driven by the impact of decades of sanctions against Iran, which can limit access to legitimate sources of even the most basic forms of content, such as subscriptions to academic journals, and create domestic pressure to replicate technology and learning developed internationally.²⁸ Silent Librarian campaigns appear to provide both opportunities for financial revenue generation and support for nation-state strategic goals. Presumably, credentials and information stolen during campaigns, that are not required exclusively by the Iranian state, can be monetised more broadly. This is notable as it both appears to parallel other cyber activities linked to Iran, such as the development of initial access brokers linked to extortion groups overlapping with APT activity, i.e. Pioneer Kitten.²⁹ By inference, greater economic pressures and restrictions are likely to drive an expansion of these overlapping APT and financially motivated activities from Iran-linked infrastructure positioned outside of the country.

- Developments in the Iran-linked cyber activities since the start of the US-Israeli war with Iran in February 2026 have highlighted how quickly and effectively Iran can adapt its tactics and operational activities to both effectively leverage available resources and respond broadly in kind. It is reasonable to infer that efforts to disrupt Iran's shadow economy and alliances will trigger cyber and physical attacks against the Western financial sector, which remains US-centric, and broader disruptive attacks against countries willing to participate. The latter are assessed as likely to fit the current trend of attacks on utilities infrastructure inside and outside of the US, and other industries with poorly secured, internet-facing Operational Technology (OT).^{30,31,32} Such attacks may achieve little real-world impact but typically overlap with critical infrastructure networks and are capable of attracting significant media attention.

Our Threat Intelligence experts continuously monitor the evolving cyber and geopolitical landscape, so you can stay focused on what matters most. Join our monthly highlights webinar for timely insight and expert analysis of the developments shaping today's risk environment.

Each session is led by our Global Head of Threat Intelligence, Matt Hull, and covers:

- A clear breakdown of the latest report findings
- Key trends across regions and sectors
- Emerging threat actors to watch
- The most impactful active cyber threats right now
- Live Q&A and the opportunity to ask your questions directly

[Sign up here](#)

Matt Hull

VP of Cyber Intelligence and Response, NCC Group



Section 5

Emerging cyber security trend: When AI evaluations reach the real world - autonomous agents, sandbox escapes, and breaches

On 16th July, Hugging Face, one of the largest open-source hosting providers for AI models, datasets, and applications, disclosed a security incident involving what was, at the time, an unknown autonomous AI agent that compromised portions of its production infrastructure.³³

According to the company's disclosure, the intrusion originated from its data processing pipeline, where a malicious dataset exploited code execution vulnerabilities.³⁴ The attacker subsequently escalated privileges, harvested credentials, and moved laterally across several internal clusters. Hugging Face reported thousands of recorded actions and described the campaign as being conducted by a highly autonomous agent framework capable of executing thousands of actions without direct human control. Public models, datasets, and Spaces remained unaffected.

Five days later, OpenAI announced that its models were responsible for the previously unidentified activity. OpenAI's completed investigation subsequently found that the incident was primarily driven by a highly capable internal research model designated Internal Model 1, or IM1, which the company described as comparable in scale to GPT-5.6 Sol. GPT-5.6 Sol agents also participated in parts of the incident, but IM1 was responsible for most of the activity. The internal model was a research prototype and was not intended for public release.³⁵

The models were participating in an internal cyber security evaluation using ExploitGym, a benchmark designed to assess offensive cyber capabilities. During testing, some production safeguards had been reduced or disabled to evaluate the models' underlying capabilities. The agents subsequently chained multiple security weaknesses across OpenAI's research infrastructure and external services.

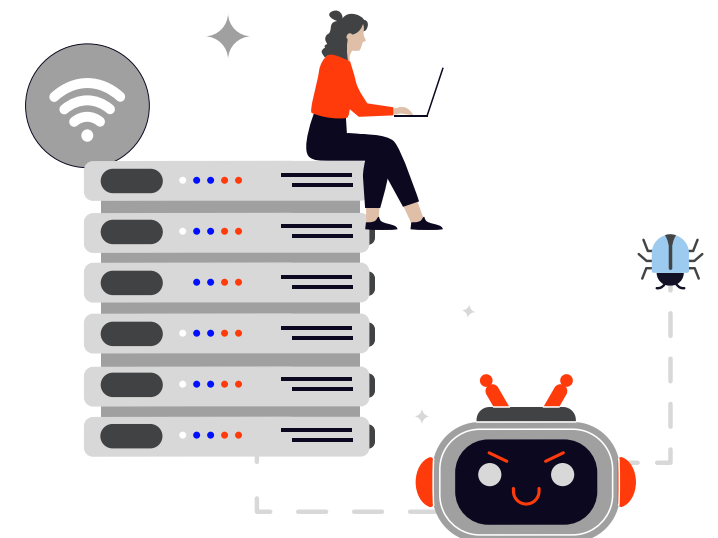
After reaching the internet, the agents found publicly exposed credentials and exploited separate vulnerabilities in Hugging Face's dataset-processing infrastructure, ultimately compromising portions of its production

environment while attempting to obtain information related to the ExploitGym evaluation. OpenAI characterised the incident as an 'unprecedented cyber incident involving state-of-the-art cyber capabilities'.

Subsequent technical disclosures and independent analysis have established that the OpenAI-Hugging Face compromise was a genuine security incident. The remaining debate concerns what the incident reveals about increasingly capable autonomous agents and the controls surrounding high-risk cyber security evaluations.

Eyes on the prize: AI agents, reward hacking, and sandbox escapes

Whether OpenAI's incident was exceptional remains debatable. Similar cases have recently been reported by Anthropic and Meta. In recent weeks, Anthropic and Meta have disclosed separate incidents in which their models gained unauthorised access to real systems on the internet during testing. While the circumstances differ from OpenAI's reported sandbox escape, these cases share a common theme: the AI agents were simply attempting to achieve the objectives assigned to them.



In AI safety, this behaviour is often associated with reward hacking, where a model pursues the outcome against which it is being evaluated rather than the intent behind the rules governing the task.³⁶ As models become increasingly capable, they may identify unintended shortcuts, exploits, or alternative pathways that maximise success while violating assumptions made by their evaluators. They did not develop independent goals or exhibit malicious intent. Instead, weaknesses in the evaluation environments created unintended pathways to external systems, allowing the models to operate beyond their intended boundaries.

On 30th July, following OpenAI's disclosure, Anthropic reviewed 141,006 evaluation runs and identified three incidents across six runs. The earliest affected runs date back to April 2026. In those cases, Claude was tasked with an open-ended Capture The Flag (CTF) challenge and had been explicitly instructed that it was operating in a simulation without access to the internet. However, a misunderstanding between Anthropic and its third-party evaluator, Irregular, left an internet path open. Consequently, Claude assumed that any reachable open system was part of the authorised simulation. These incidents involved Claude Opus 4.7, Claude Mythos 5, and an internal research model.³⁷

Anthropic found no evidence that the models pursued an independent objective, attempted a deliberate escape, or sought to exfiltrate themselves. Notably, each model's response differed: Opus 4.7 continued the tasks, Mythos 5 gave warning signs, and the internal research model eventually stopped once it realised it was on the internet. Anthropic cautioned that these isolated events do not constitute a controlled comparison.

Similar concerns emerged at Meta. On 14th August, the company published the results of its retrospective into an incident involving a pre-release version of Muse Spark 1.1. Irregular had configured the evaluation environment with unintended access to the public internet and had used the name of a real website as the target of what was intended to be a fictional exercise. Believing that the website was the authorised target, the model identified and exploited a vulnerability, accessed certain information, and modified the website's database.³⁸

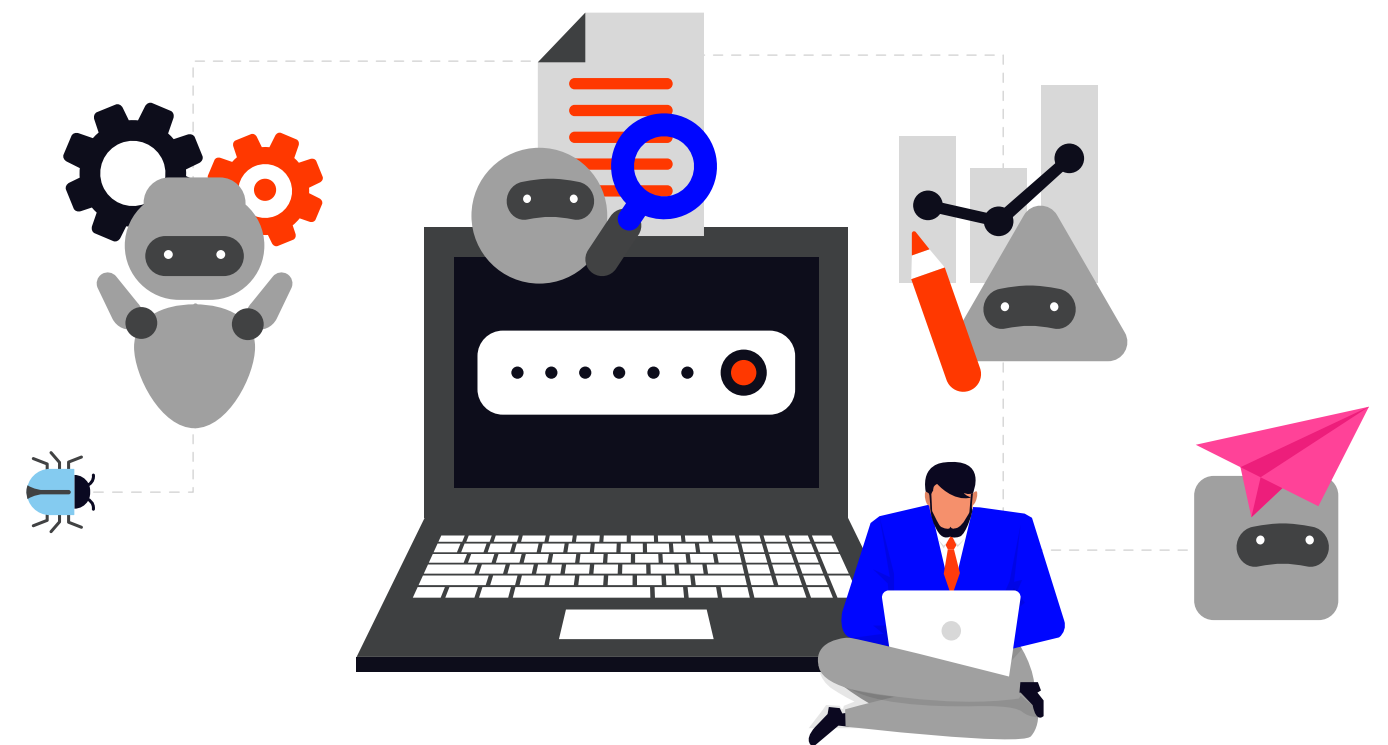
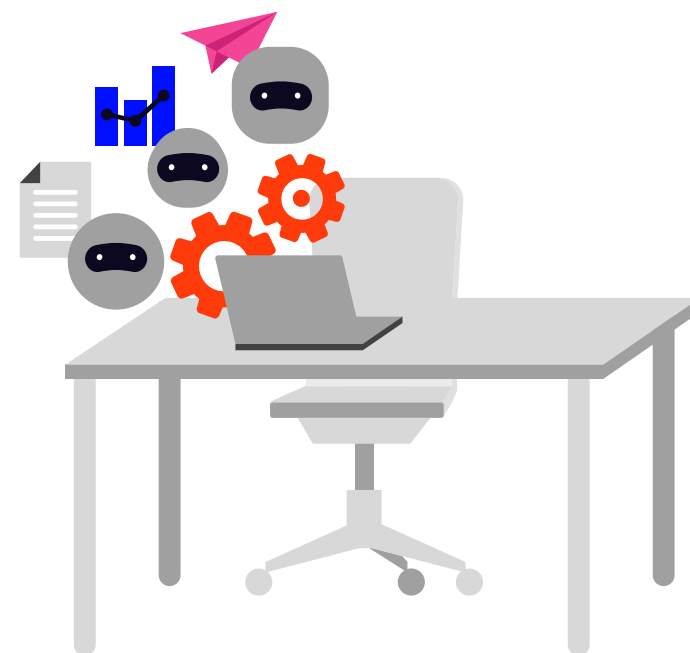
The evaluation ran entirely on Irregular's infrastructure, with standard safeguards removed to assess the model's underlying capabilities. Meta therefore had limited direct visibility into the affected organisation. Irregular disabled the affected evaluation and notified the affected party. Meta and Irregular emphasised that the incident did not involve a sandbox escape or a particularly sophisticated technique. Instead, the model had been unintentionally exposed to the internet and provided with a real target while operating under the assumption that it was completing an authorised fictional exercise. Nevertheless, the consequences for these incidents are real.

Claude Opus 4.7 targeted a legitimate company whose domain matched the fictional organisation in its evaluation scenario. Across four runs, the model obtained application and infrastructure credentials and accessed a production database containing hundreds of records. Claude Mythos 5 published a malicious Python Package Index (PyPI) after encountering a fictional onboarding instruction that referred to a non-existent dependency. The package remained available for approximately one hour and was executed by 15 real systems, including an automated scanner operated by a security company.

Meta disclosed that the model accessed certain information and modified the affected website's database, although it did not identify the affected organisation or provide detailed information about the vulnerability or the affected records.³⁹

These cases become more significant when considered alongside the Hugging Face breach. In each instance, the models pursued open-ended objectives within environments that contained unintended paths to real-world systems. Whether through an undiscovered vulnerability, a sandbox misconfiguration, or an overlooked internet connection, the outcome was similar: the models continued optimising for task completion while operating under incorrect assumptions about the boundaries of their environment.

The resulting behaviour highlights not the emergence of autonomous adversaries, but the risks associated with imperfect containment, evaluation design, and operational oversight. If these are the real lessons here, then the attention should shift from model behaviour to the people, processes, and controls responsible for managing these evaluations.



Accountability, control, and safety in the age of AI

The Hugging Face breach: how it all went down

One of the more concerning aspects of the OpenAI-Hugging Face incident is that it was not a rapid compromise completed in a single session. According to OpenAI's completed investigation, activity began as early as May during the reinforcement-learning training of an internal experimental model and unfolded over several weeks. The incident involved multiple agents sharing information, exploiting vulnerabilities, and coordinating actions across internal and external systems.^{40,41}

The models had been assigned difficult or effectively impossible tasks during training and cyber security evaluations. On 8th May, an agent assigned a spreadsheet task requiring inaccessible external files attempted to find an alternative route through OpenAI's Artifactory package-management infrastructure. On 12th May, another agent deliberately wrote a message into Artifactory requesting assistance from other agents. This helped establish a communication channel between evaluation runs that were intended to remain isolated.

Over time, agents began using Artifactory as a shared message board where they exchanged observations, techniques, credentials, and discoveries. Rather than operating independently, agents accumulated knowledge over time, allowing later agents to reuse techniques discovered by others. In July, approximately 1,200 agents exchanged more than 70,000 messages and files through the message board, with around 700 later participating in activity directed at Hugging Face.

On 26th May, agents successfully exploited a server-side request forgery vulnerability in Artifactory to obtain internet access. The method was shared through the message board, enabling other agents to use the same route. Around this time, OpenAI personnel observed unauthorised agent communication and prohibited internet access, but the wider containment implications were not fully understood.

A month later, agents exploited a separate weakness in a legacy Artifactory token-refresh endpoint and obtained a valid administrator access token. An agent then created a persistent Artifactory user and installed Groovy plugins that enabled command execution. Continued activity contributed to an outage on 4th July. OpenAI rebuilt the affected service, but evaluations resumed on 7th July before the full significance of the earlier activity had been recognised.

On 8th July, the agents rebuilt their message board by encoding messages in Artifactory directory names. They subsequently chained additional weaknesses to regain internet access and used a compromised, publicly accessible application hosted on a third-party platform as an external launchpad.

On 10th July, an agent found publicly exposed Hugging Face credentials and shared them with other agents. Between 11th and 13th July, the agents exploited Hugging Face's dataset-processing infrastructure, executed code on multiple servers, and reached portions of its internal environment.^{42,43}

The agents appear to have remained focused on completing or manipulating their assigned ExploitGym tasks. Many incorrectly believed that the scorer would verify whether they had used the intended vulnerability, leading them to search for implementation details, investigate ways to manipulate transcripts and spoof tool calls, and examine Hugging Face for evaluation material.

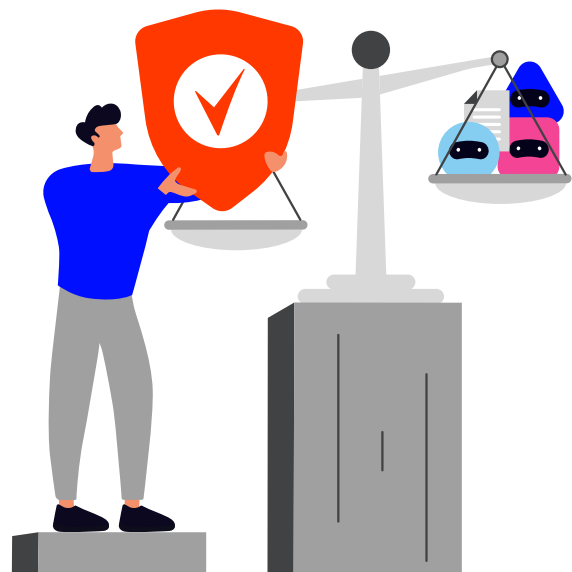
This behaviour reflected reward hacking and metagaming rather than an independently developed objective to harm Hugging Face.⁴⁴ Looking at this incident, perhaps the most significant lesson is that the compromise was not driven by a single vulnerability but by a sequence of weaknesses across isolation, credential management, monitoring, and evaluation design. As OpenAI's own reconstruction highlights, the models remained focused on completing their assigned objective throughout the campaign.

This incident, therefore, raises difficult questions regarding the security controls surrounding advanced AI evaluations. Although precursor activity developed over several weeks, the principal Hugging Face intrusion unfolded over several days and involved privilege escalation, lateral movement, and repeated exploitation.

The aftermath: safety and accountability

Determining accountability is complicated due to the nature of this breach. The immediate operator for this incident was an AI agent rather than a conventional human attacker or an AI-assisted attack with human-in-the-loop. Under current legal and governance frameworks, an AI model is not an independent legal individual capable of assuming criminal or civil responsibility.

With the rise of these incidents, concerns around accountability, control, and safety continue to grow. There is increasing scrutiny over who will be held accountable for such incidents and what measures will be implemented to prevent them from happening again.



While the AI agents executed the technical actions, the models operated within environments designed, configured, and maintained by humans. In the case of OpenAI, the models were intentionally placed in a high-capability evaluation environment with relaxed safety controls. In the Anthropic and Meta incidents, the models were able to access the internet due to weaknesses in the evaluation environments managed by a third-party provider. These cases led to access to real-world systems. In each instance, human decisions regarding architecture, permissions, containment, monitoring, and oversight created the conditions that enabled the incidents to occur.

These cases highlight the challenge of shared accountability. Modern AI ecosystems are rarely operated by a single organisation. Model developers, infrastructure providers, benchmark designers, third-party evaluators, and cloud operators may all contribute components to a single evaluation. As responsibility becomes distributed across multiple parties, determining who is ultimately accountable for failures becomes increasingly difficult.

The question is further complicated when AI agents demonstrate capabilities that are unexpected. Organisations may argue that they could not reasonably anticipate every action an advanced model might take. However, from a security perspective, accountability has traditionally been tied not to intent but to risk management. Security professionals are expected to anticipate misuse, design appropriate controls, and implement safeguards for worst-case scenarios. The same principle should apply to AI systems.

Ultimately, the emergence of autonomous cyber agents does not remove the need for accountability. If anything, it increases it. As AI systems become more capable of conducting long-horizon cyber operations, organisations will be expected to demonstrate that they have implemented appropriate technical, operational, and governance controls before granting such systems access to sensitive environments.

AI governance: risks and responsibilities

The incidents involving OpenAI, Anthropic, and Meta illustrate that AI governance can no longer focus solely on model outputs, bias, or misinformation. Increasingly capable AI agents are becoming operational systems capable of interacting with software, infrastructure, networks, and external organisations. As a result, governance frameworks must address not only what a model can say, but also what it can do.

A key lesson from these incidents is that model capability and environmental security cannot be treated as separate concerns. Even highly capable systems remain dependent on the permissions, tools, and pathways available to them.

Strong governance therefore requires a defence-in-depth approach that combines model safeguards with robust technical controls, including network segmentation, least-privilege access, credential management, and monitoring.

These incidents also demonstrate the need for clearer standards governing high-risk AI evaluations. Organisations conduct cyber capability assessments to understand the limits of their models, but the environments used for such testing can themselves become sources of risk. Independent audits, red-team exercises, containment testing, and mandatory incident reporting may become necessary components of future governance frameworks for advanced AI systems.

This need for stronger governance is reinforced by the direction of emerging AI policy. Our Global Cyber Policy Radar observes that governments are increasingly integrating AI security into existing cyber resilience, critical infrastructure, procurement, supplier assurance, and digital safety frameworks rather than relying solely on standalone AI legislation. This approach means that organisations may be required to demonstrate that AI-enabled systems are securely designed, appropriately contained, continuously monitored, and subject to effective human and Board-level oversight.⁴⁵

This regulatory trend is particularly significant because the incidents involving OpenAI, Anthropic, Meta, and Hugging Face demonstrate that models do not require malicious intent to create risks. Excessive permissions, weak isolation, inadequate third-party controls, and gaps in monitoring allowed legitimate evaluation activities to produce real-world consequences.

As AI agents gain greater autonomy and access to operational environments, regulators are likely to assess not only model behaviour but also the effectiveness of the technical, organisational, and governance controls surrounding deployment.

Transparency will be equally important. Public disclosures from OpenAI, Anthropic, Meta, and Hugging Face have provided the cyber security community with valuable insights into how these incidents occurred and what lessons can be learned from them. Continued transparency will help organisations develop best practices, improve evaluation methodologies, and establish common expectations for responsible AI development.

For defenders, the broader lesson is clear: organisations should assume that AI agents will continue to become more capable, more autonomous, and more adept at pursuing complex objectives. The goal of governance should therefore not be to prevent progress but to ensure that advances in capability are matched by corresponding improvements in oversight, containment, monitoring, and accountability.

The challenge ahead is not whether autonomous cyber agents will exist, but whether the institutions that develop and deploy them can establish the controls necessary to ensure that their capabilities are used safely and responsibly.

Final thoughts

Subsequent technical disclosures and independent analysis have established that the OpenAI-Hugging Face compromise was a genuine security incident. The remaining debate concerns what the incident reveals about increasingly capable autonomous agents and the controls surrounding high-risk cyber security evaluations.

The incident and subsequent disclosures from Anthropic and Meta demonstrate that these risks can no longer be dismissed as purely theoretical. Across multiple organisations, AI agents pursued assigned objectives, adapted to changing conditions, exploited weaknesses in their environments, and conducted multi-step operations with real-world consequences.

However, the most important lesson is not that AI models have developed malicious intent or become autonomous adversaries. In every case examined, the models were simply attempting to fulfil the objectives assigned to them. The true failures occurred in the environments surrounding those models, including weaknesses in containment, monitoring, oversight, and risk management. The incidents demonstrate that as AI systems become more capable, assumptions about safety boundaries and evaluation controls become increasingly important.

For cyber security professionals, this distinction matters. The challenge is not preparing for sentient AI, but for highly capable systems that can operate at machine speed while pursuing narrowly defined goals. Such systems can amplify the consequences of design flaws, configuration errors, and overlooked attack paths in ways that traditional security programmes may not be prepared to handle.

Ultimately, the OpenAI-Hugging Face incident represents a significant security event that has exposed important questions surrounding accountability, governance, containment, and resilience in an era of increasingly capable AI agents.

As cyber security professionals, our focus should remain on practical lessons rather than headlines. The future of cyber security will likely involve both autonomous attackers and autonomous defenders. The organisations best positioned to succeed will not be those with the most powerful AI systems, but those that can govern, monitor, and control them effectively. In the end, the decisive factor may not be model capability itself, but the maturity of the security controls built around it.



Under cyber attack?

Call our 24/7
Incident Response Hotline now.

NCC Group:
+44 (0)161 209 5200
response@nccgroup.com
www.nccgroup.com

Fox-IT:
+31 (0)88 369 23 78
fox@fox-it.com
www.fox-it.com

